

HALCYON BENEFITS GROUP — AI GOVERNANCE CONTROL CROSSWALK

Sample GRC portfolio artifact | Maps each control objective across NIST AI RMF, ISO/IEC 42001 Annex A, EU AI Act (high-risk obligations), and the existing NIST CSF 2.0 security program | Verify citations against current published texts

Control Domain	Control Objective	NIST AI RMF (Function / Subcategory)	ISO/IEC 42001 Annex A	EU AI Act (Article — high-risk unless noted)	NIST CSF 2.0 (existing program)	Implementation Status	Evidence Expected	Related Risk IDs	Owner
Governance	Establish accountable AI governance body with defined roles, policy, and risk tolerance	GOVERN 1.1, 1.2, 2.1, 3.1	A.2.2, A.2.3, A.3.2	Art. 9 (risk mgmt system) — organizational prerequisite	GV.RR, GV.RM	Not Implemented	Committee charter; AI policy; RACI; meeting minutes	AIR-012	General Counsel
Governance	Maintain a complete inventory of AI systems with classification and ownership	MAP 1.1, 1.6; GOVERN 1.6	A.4.2, A.4.3	Art. 49 (registration, high-risk); Art. 26 (deployer obligations)	ID.AM-01/02 (extended)	Partially Implemented	AI System Inventory (this package); quarterly refresh record	AIR-012	CISO
Governance	Acceptable use policy for AI tools, incl. prohibition on consumer tools for sensitive data	GOVERN 1.1, 4.1	A.2.2, A.6.2.5	Art. 4 (AI literacy) — supporting	GV.PO, PR.AT	Not Implemented	Signed policy; attestation records; CASB block rules	AIR-010	CISO
Risk Management	Perform documented AI risk assessment per system, refreshed on material change	MAP 5.1; MEASURE 2.x; MANAGE 1.x	A.5.2, A.5.3, A.5.4	Art. 9 (risk mgmt system, continuous)	ID.RA	Partially Implemented	AI Risk Assessment (this package); change-triggered reassessment log	All	GRC Lead
Risk Management	Fundamental rights / algorithmic impact assessment for high-risk uses	MAP 1.1, 3.x; MEASURE 2.11	A.5.4, A.5.5	Art. 27 (FRIA — deployers of certain high-risk systems)	—	Not Implemented	Completed impact assessment per high-risk system	AIR-001, AIR-005	GRC Lead + Legal
Data Governance	Training/validation/test data provenance, quality, and bias examination documented	MAP 2.x; MEASURE 2.6	A.7.2, A.7.3, A.7.4	Art. 10 (data and data governance)	—	Not Implemented	Data cards; provenance records; bias examination report	AIR-001	Head of Data Science
Data Governance	Personal data minimization and access scoping for AI systems that ingest sensitive data	MAP 1.6; MANAGE 2.x	A.7.5, A.7.6	Art. 10(5); GDPR interplay	PR.DS-01, PR.AA-05	Partially Implemented	Access review; DLP config; Copilot index scope	AIR-009, AIR-010	CIO
Fairness	Disparate-impact testing across protected classes with defined thresholds and remediation triggers	MEASURE 2.11; MANAGE 2.4	A.6.2.4, A.5.4	Art. 10(2)(f)-(g); Art. 15	—	Not Implemented	Fairness test report; threshold definitions; retraining record	AIR-001, AIR-005	Head of Data Science
Transparency	Disclose AI interaction to natural persons; provide meaningful information on AI-influenced decisions	MAP 1.6, 5.x; GOVERN 4.x	A.8.2, A.8.3, A.8.4	Art. 50 (transparency); Art. 13 (instructions for use); Art. 86 (explanation right)	—	Partially Implemented	Disclosure UX; adverse-action notice template; user documentation	AIR-002, AIR-007	Director of Member Services
Human Oversight	Effective (not nominal) human oversight with authority and competence to override	MANAGE 2.4; GOVERN 3.2	A.9.2, A.9.3	Art. 14 (human oversight)	—	Partially Implemented	Override rate monitoring; oversight training records; escalation path	AIR-001, AIR-005	VP Claims / VP People
Performance	In-production monitoring for accuracy, drift, and degradation with retraining triggers	MEASURE 2.5, 2.6, 4.x; MANAGE 4.1	A.6.2.6, A.6.2.7	Art. 15 (accuracy, robustness); Art. 72 (post-market monitoring)	DE.CM (extended)	Partially Implemented	Drift dashboards; monthly performance report; retraining log	AIR-003, AIR-006	Head of Data Science
Security	Adversarial testing incl. prompt injection, data poisoning, model extraction	MEASURE 2.7; MANAGE 2.x	A.6.2.6 (extended)	Art. 15 (cybersecurity)	ID.RA-01, PR.PS	Not Implemented	Red-team report against OWASP LLM Top 10 / MITRE ATLAS; remediation tracker	AIR-008	CISO
Third Party	AI-specific vendor due diligence: training data disclosure, bias audit, transparency documentation	GOVERN 6.1, 6.2; MAP 4.x	A.10.2, A.10.3	Art. 25 (value chain); Art. 13	GV.SC-06/07	Partially Implemented	AI vendor questionnaire; contract clauses; audit report receipt	AIR-005, AIR-011	Vendor Risk Manager
Incident	AI incident identification, response, and reporting incl. serious-incident notification	MANAGE 4.3; MEASURE 3.x	A.6.2.8, A.8.5	Art. 73 (serious incident reporting)	RS.MA, RS.CO (extended)	Not Implemented	AI incident taxonomy; playbook; reporting decision tree	AIR-006, AIR-008	CISO
Documentation	Technical documentation sufficient for conformity assessment and audit	GOVERN 1.4; MAP 1.x	A.6.2.3	Art. 11 + Annex IV (technical documentation); Art. 12 (logging)	—	Not Implemented	Model cards; system documentation per Annex IV; decision logs	AIR-004	Head of Data Science + Legal

IMPLEMENTATION SUMMARY

Status	Count	% of Controls
Implemented	0	0.0%
Partially Implemented	7	46.7%
Not Implemented	8	53.3%

Reading this

Zero controls fully implemented is the honest starting posture of an organization that deployed AI before governing it. The value of this crosswalk is that one control implementation — a fairness testing program, say — closes an AI RMF subcategory, an ISO 42001 Annex A control, an EU AI Act article, and a risk register item simultaneously. Build once, evidence four ways.

CROSSWALK NOTES

Why four columns	NIST AI RMF is the method (voluntary, no certification). ISO/IEC 42001 is the certifiable management system that proves the method is real. The EU AI Act is the legal floor. NIST CSF 2.0 is the security program Halcyon already runs — the AI controls extend it rather than duplicating it.
Mapping principle	Map to the control objective, not the wording. AI RMF subcategories, 42001 Annex A controls, and AI Act articles overlap heavily but imperfectly; the mapping is many-to-many. Where an AI-specific control has no CSF equivalent, the CSF column reads '—' — that gap is itself a finding: the existing security program was not designed for these risks.
EU AI Act column	Cites high-risk obligations (Arts. 9-15) and cross-cutting articles (4, 25, 26, 27, 49, 50, 72, 73, 86). Applicability depends on the system's tier per the inventory. Article numbers reflect the adopted regulation; the May 2026 Digital Omnibus proposal affects timelines, not article structure, but verify before citing.
Implementation status	Reflects Halcyon at inventory date. 'Partially' means something exists but was not designed for AI (e.g., generic vendor questionnaire with no AI questions).
Not legal advice	Article and clause citations are for demonstration and should be verified against current published texts by qualified counsel before reliance.